



Security and Outsourcing Due Diligence

Pre-filled vendor questionnaire

Prepared by – **iorta TechNXT**

Version – **1.0**

Date – **03 October 2026**

TABLE OF CONTENTS

1. Document Control.....	3
2. Acronyms.....	3
3. About this questionnaire.....	4
3.1 Purpose.....	4
3.2 How the answers are written.....	5
3.3 Evidence documents.....	5
4. Company and governance.....	6
5. Regulatory: Insurance Commission and outsourcing.....	8
6. Regulatory: Data Privacy Act.....	10
7. Access control.....	12
8. Cryptography and key management.....	14
9. Application and infrastructure security.....	15
10. Logging and monitoring.....	17
11. Vulnerability and patch management.....	18
12. Secure development and change management.....	19
13. Backup, continuity and disaster recovery.....	20
14. Incident management.....	21
15. Subcontractors, hosting and data residency.....	22
16. Audit and assurance.....	23
17. Open items before release to a broker.....	24
18. Document Sign-Off.....	25

1. Document Control

Date	Version	Author & Business Unit Info	Reviewed By & Business Unit Info	Approved By & Business Unit Info	Change History
03 October 2026	1.0	iorta TechNXT			Initial issue

2. Acronyms

Acronym / Symbol	Definition / Meaning
OOTB	Out of the box
IC	Insurance Commission
NPC	National Privacy Commission
DPA	Data Privacy Act of 2012 (RA 10173)
IRR	Implementing Rules and Regulations
DPO	Data Protection Officer
PIC	Personal information controller
PIP	Personal information processor
ISMS	Information security management system
ISO	International Organization for Standardization
SOC	System and Organization Controls
MFA	Multi-factor authentication
TOTP	Time-based one-time password
TLS	Transport Layer Security
KMS	Key management service
WAF	Web application firewall
RTO	Recovery time objective
RPO	Recovery point objective
PITR	Point-in-time recovery

SDLC	Secure development lifecycle
CI	Continuous integration
OWASP	Open Worldwide Application Security Project
SoD	Segregation of duties
CAB	Change advisory board
DR	Disaster recovery
PCI DSS	Payment Card Industry Data Security Standard
DEV	Development environment
SIT	System integration test
PRE-PROD	Pre-production environment
PROD	Production environment

3. About this questionnaire

3.1 Purpose

Philippine insurance brokers, their internal auditors and their external auditors send a security and outsourcing questionnaire before they sign with a software or hosting provider. This document gives iorta TechNXT's pre-filled answers for BrokerVerse OOTB so the broker's review can start from facts instead of a blank form. The same answers are in the companion workbook

BrokerVerse_Security_Due_Diligence_Questionnaire.xlsx (one row per question, with the answer and the evidence document), which the broker can copy into its own template.

The questions follow the areas the reviewers usually cover: the Insurance Commission's expectations on IT risk and outsourcing, the Data Privacy Act of 2012 with its IRR and NPC circulars, and ISO/IEC 27001-style control areas.

3.2 How the answers are written

- Answers describe the product as delivered on branch brokerverse-platform on 03 October 2026, the deployment package and the contract templates of the OOTB package.
- **Response** is one of: **Yes** (in place today), **Partial** (in place with a stated limit), **No** (not in place), **Planned** (on the product backlog), **Broker** (the broker's own control, outside iorta TechNXT's scope) or **N/A**.
- Where iorta TechNXT hosts the system, hosting controls are those of the Hosting and Infrastructure Services Agreement. Where the broker hosts, the same controls are the broker's, and the Architecture document gives the recommended set-up.
- Items marked **[to confirm]** are organisational facts about iorta TechNXT that are not recorded in the package. They must be answered by iorta TechNXT management before the questionnaire is given to a broker. Nothing has been assumed for them.

This document is not legal advice. The broker's compliance officer and DPO decide how the IC circulars and NPC rules apply to the broker.

3.3 Evidence documents

Code	Document
AIS	Architecture, Infrastructure, Security and Data Privacy
TR	Technical Reference (code structure, standards, APIs and security controls in code)
TSR	Test Summary Report and the Test Cases workbook
PSS	Production Support Approach and Standards
BCDR	Business Continuity and Disaster Recovery Plan
PRCM	Philippine Regulatory Compliance Matrix
PF	Product Functionality
IAP	Implementation Approach and Plan
MSA	Master Services Agreement
DPA	Data Processing Agreement
HSA	Hosting and Infrastructure Services Agreement
SLA	Annual Maintenance, Support and SLA
ESC	Source Code Escrow Agreement (optional annex to the perpetual licence)
ARCH 08, 09, 11	Solution Architecture documents RTO and RPO, Backup and Recovery, Monitoring

4. Company and governance

Ref	Question	Response	Answer	Evidence
GOV-01	Legal name, registration and address of the provider	Partial	iorta TechNXT Corp., a Philippine corporation. SEC registration number, TIN and principal office address: [to confirm]	MSA, Parties
GOV-02	Who owns the software and who develops and supports it	Yes	iorta TechNXT owns iNXT BrokerVerse and provides implementation (L2) and engineering support (L3). Location of the development and support teams: [to confirm]	MSA; PSS, Support model
GOV-03	Does the provider have a documented information security policy approved by management	Partial	Security controls of the product and the hosting are documented in AIS and HSA. A company-wide information security policy and its approval date: [to confirm]	AIS, Security architecture
GOV-04	Is there a named person responsible for information security	Partial	Named security officer of iorta TechNXT: [to confirm]. Security incidents are handled by iorta TechNXT engineering (L3) as P1	PSS, Security incidents
GOV-05	Has the provider appointed a DPO and registered with the NPC	Partial	iorta TechNXT acts as PIP for the broker. DPO name and NPC registration of iorta TechNXT: [to confirm]	DPA, Roles
GOV-06	Does the provider hold ISO/IEC 27001 certification	No	Not held by iorta TechNXT at the date of this document. Certification plan and target date: [to confirm]. The cloud providers of hosting options A and B publish their own ISO/IEC 27001 certificates	HSA; AIS, Option A and B
GOV-07	Does the provider have a SOC 2 Type II report	No	Not held. Roadmap: [to confirm]. AWS and Microsoft Azure make their SOC reports available to their customers through their compliance portals	HSA
GOV-08	Is the provider PCI DSS certified	N/A	BrokerVerse never receives card numbers. Card details are entered on the payment gateway's own page (PayMongo or Dragonpay); the broker uses gateways that hold PCI DSS certification	AIS, Personal data held
GOV-09	Are security risks assessed and recorded	Partial	Product risks are recorded as Gap items in AIS and as defects in TSR (open: Medium 3, Low 5, no Critical or High). A company risk register: [to confirm]	AIS; TSR, Defects
GOV-10	Are staff screened before hiring	Partial	Background check practice for staff with production access: [to confirm]	MSA, Personnel
GOV-11	Are staff bound by confidentiality	Yes	Every person who processes the broker's personal data is bound by confidentiality, trained in data privacy, and the duty continues after the person leaves	DPA, Confidentiality; MSA, Confidentiality

Ref	Question	Response	Answer	Evidence
GOV-12	Do staff receive security and privacy awareness training	Partial	Required by the DPA template for personnel handling personal data. Training programme and frequency: [to confirm]	DPA, Confidentiality
GOV-13	Does the provider carry professional indemnity or cyber insurance	Partial	[to confirm: insurer, cover and limit]	MSA
GOV-14	Is the provider financially stable; what protects the broker if it fails	Partial	Financial statements: [to confirm]. Protection for the broker: the broker may host the system itself; data return on exit; optional source code escrow with the perpetual licence	ESC; MSA; Exit and Transition Plan

5. Regulatory: Insurance Commission and outsourcing

Ref	Question	Response	Answer	Evidence
REG-01	Which IC circulars on IT risk and outsourcing have been considered	Partial	The package maps the system to the Insurance Code (RA 10607) record-keeping and premium handling rules. The specific IC circulars on IT risk management and outsourcing that apply to the broker are identified by the broker's compliance officer [to confirm circular numbers with the broker]	PRCM; AIS, Insurance Commission and records
REG-02	Does the outsourcing keep the broker in control of its books and records	Yes	All policy, premium, commission, remittance and ledger records are in the broker's database; reports export to Excel, CSV and PDF; the broker can obtain a full export at any time and on exit	AIS, IC and records; Exit and Transition Plan
REG-03	Can the IC examine the broker's records held in the system	Yes	Registers, reports and the audit trail are available to the broker for IC examination. The MSA allows disclosure to the IC when required. An explicit right of access for the IC to iorta TechNXT premises: [to confirm in the MSA]	MSA, Confidentiality; AIS
REG-04	Does the system keep premiums due to insurers apart	Yes	Premium trust bank account in the masters; amounts due to each insurer in the ledger; remittance with approval; remittance ageing on the insurer's terms	PRCM; PF, Remittance
REG-05	Is there a written outsourcing agreement covering services, SLAs, confidentiality, data, audit and exit	Yes	MSA with the Statement of Work, Support and SLA, Hosting Agreement, DPA and Exit and Transition Plan	MSA; SLA; HSA; DPA
REG-06	Are service levels defined and reported	Yes	Severity P1 to P4 with response and restore targets; availability target 99.5% for hosted production; monthly service report and review	SLA; PSS, Severity levels; HSA, Availability
REG-07	Can the broker terminate and get its data back	Yes	Data returned in an agreed format and deleted within 30 days after the broker confirms the export, with a certificate of deletion	HSA, Exit; DPA; Exit and Transition Plan
REG-08	Does the provider support the broker's BIR obligations	Partial	BIR working papers (Form 2307, VAT Summary, SAWT, QAP, SLSP) from the ledger. Registration of the system as a Computerized Accounting System and filing remain with the broker	PRCM, BIR
REG-09	Does the system support anti-money laundering checks	Partial	KYC data (government ID type, number and image) required before motor issue. No transaction	PRCM, AMLA; PF

Ref	Question	Response	Answer	Evidence
			monitoring, sanctions or PEP screening, or AMLC reporting	

6. Regulatory: Data Privacy Act

Ref	Question	Response	Answer	Evidence
DPA-01	What is the role of iorta TechNXT under the DPA	Yes	The broker is the PIC. iorta TechNXT is a PIP when it hosts, supports or accesses production data, and acts only on the broker's documented instructions	DPA; AIS, Roles under the DPA
DPA-02	Is a data processing agreement signed	Yes	Template DPA covering subject matter, instructions, confidentiality, security measures, sub-processors, assistance, breach notice, return and deletion, and audits	DPA
DPA-03	What personal data does the system hold	Yes	Leads, clients, insured risks, KYC IDs and images, claimants and payees, payment references (no card numbers), referrers and their bank accounts, staff users and sign-in history	AIS, Personal data held
DPA-04	Does it hold sensitive personal information	Yes	Government-issued ID numbers and images; some claim details (for example injury in a personal accident claim)	AIS, Personal data held
DPA-05	Can consent be recorded	Yes	Master > Data Privacy > Consent Register and consent per purpose on the client and prospect (processing, marketing, sharing with insurers), with channel, notice version and evidence. Delivered after the release test and re-tested on 03 October 2026 (BV-SEC-034 passed)	PF, Data privacy; TSR, BV-DEF-002
DPA-06	Can data subject requests be logged and answered	Yes	Master > Data Privacy > Data Subject Requests (DSR- numbers), due date 15 calendar days (privacy.request_due_days) , personal data export as JSON or Excel. Re-tested on 03 October 2026 (BV-SEC-035 passed)	PF, Data privacy
DPA-07	Can personal data be erased or anonymised	Yes	Anonymisation of a client or prospect with a dry run, refused while policies are in force, items are open, or within 10 years of the last expiry (privacy.retention_years); every action in the audit trail	PF, Data privacy
DPA-08	Is personal data encrypted	Partial	In transit: TLS. At rest: storage encryption of the database, file store and backups (included in hosted options; recommended when the broker hosts). Inside the application only two-step verification secrets are encrypted (AES-256-GCM); field-level encryption of personal identifiers is on	AIS, Encryption; TSR

Ref	Question	Response	Answer	Evidence
			the backlog (BV-DEF-003)	
DPA-09	Where is the data stored	Yes	Chosen per broker: AWS or Azure in Singapore, a Philippine hosting partner, or the broker's own data centre. Stated in the Order Form; not moved without the broker's written consent	HSA, Data location; AIS, Cross-border transfer
DPA-10	How are cross-border transfers handled	Broker	Hosting in Singapore is a transfer the DPA allows; the broker remains accountable (DPA section 21), documents it in its privacy notice, processing records and privacy impact assessment; iorta TechNXT provides comparable protection by contract	DPA, Location; AIS
DPA-11	What is the breach notification commitment	Yes	iorta TechNXT notifies the broker's DPO and System Administrator without undue delay and within [24] hours of discovery, never later than 72 hours; written incident report within [5] business days of containment. The broker notifies the NPC and data subjects within 72 hours where NPC Circular 16-03 requires	DPA, Personal data breach; PSS
DPA-12	Is there a retention schedule	Partial	Housekeeping job removes temporary data on configured periods; audit trail kept by default and never purged below 7 years; business records kept; personal data of a client or prospect anonymised on request once <code>privacy.retention_years</code> (10) has passed; recommended retention of 10 years for financial and policy records, confirmed by the broker	AIS, Retention and disposal
DPA-13	Who are the sub-processors	Yes	The hosting provider of the chosen option, and the e-mail provider or support tooling only where they apply. Listed in DPA Annex 3; 30 days' notice before a change, with a right to object	DPA, Sub-processors and Annex 3
DPA-14	Has a privacy impact assessment been done	Broker	The PIA is the broker's as PIC. iorta TechNXT supplies the system description, data inventory and security measures (AIS) as input	AIS, Data privacy
DPA-15	Are NPC registration and the privacy notice handled	Broker	Registration of the processing system and DPO (NPC Circular 2022-04) and the privacy notice are the broker's. The notice version is recorded with each consent (<code>privacy.notice_version</code>)	AIS, Legal framework; PF

7. Access control

Ref	Question	Response	Answer	Evidence
ACC-01	Are all users uniquely identified	Yes	Named users only; no shared or agent sign-in. The initial password must be changed at first sign-in	AIS, Identity and authentication
ACC-02	What is the password policy	Yes	Minimum 8 characters with upper case, lower case, digit and symbol; last 5 passwords refused; maximum age 90 days. All values are settings (security.password_*)	TR, Password policy
ACC-03	How are passwords stored	Yes	bcrypt hash (cost 10). An unknown user name costs the same comparison time, so names cannot be discovered by timing	TR, Authentication
ACC-04	Is there an account lockout	Yes	Locked after 5 wrong passwords (limits.max_login_attempts); sign-in and forgot-password limited to 10 attempts per 5 minutes per IP and per user name; reopening a locked account is audited	TR; TSR, Security testing
ACC-05	Is multi-factor authentication available	Yes	TOTP to RFC 6238 with any authenticator app; a code cannot be reused; compulsory for the roles in security.require_2fa_roles (empty when delivered; set at go-live for at least System Administrator, Accounting and Accounting Manager)	TR; AIS
ACC-06	How are sessions controlled	Yes	Access token 30 minutes; refresh token 30 days, rotated on each use, reuse revokes the token family; idle sign-out after 30 minutes with a warning	TR, Authentication
ACC-07	Can sessions be ended centrally	Yes	Password change or reset, deactivation, role change and Sign out everywhere end every session of the user at once (token version)	TR, Authentication
ACC-08	Where are session tokens stored in the browser	Partial	In browser local storage, accepted for go-live; a move to an httpOnly cookie is planned	AIS, Known limitation
ACC-09	Is access role-based and least privilege	Yes	Seven delivered roles; permissions checked by the server on every route (807 of 868 routes need a permission or role, 42 need sign-in only, 19 are public by design); menus deny by default	TR, Authorisation
ACC-10	Can users be restricted to their own records	Yes	Roles in security.scoped_roles see only their own book; another user's record answers 404	TR, Authorisation
ACC-11	Is there segregation of duties	Yes	SoD rules on role pairs checked at assignment (block or warn); maker-checker on approvals; authority matrix limits in PHP per transaction type and role	AIS, Authorisation; PF
ACC-12	How are privileged accounts controlled	Yes	Only a System Administrator can grant that role or change an administrator; nobody can change their own roles or	AIS, Authorisation

Ref	Question	Response	Answer	Evidence
			status; all changes audited	
ACC-13	Are access rights reviewed	Yes	Access Reviews campaigns in Master > Generals > User Management; revoke deactivates and signs out; User Access Matrix and Role Permissions exports	AIS; PF
ACC-14	Are dormant accounts disabled	Yes	Daily job deactivates accounts without a sign-in for 90 days (access.dormant_days), the built-in administrator excepted	AIS, Archival and housekeeping
ACC-15	Who approves joiners, movers and leavers	Broker	The broker requests, approves and removes access; the System Administrator executes in User Management	AIS, Compliance checklist
ACC-16	How is iorta TechNXT staff access to production controlled	Partial	Recommended design: management zone with bastion or session manager, multi-factor sign-in, logged. Named list of iorta TechNXT staff with production access and the approval process: [to confirm]	AIS, Network zones; HSA
ACC-17	Are infrastructure administrator actions logged	Partial	Cloud provider audit logs (for example AWS CloudTrail) on hosted options [to confirm that the hosting runbook enables them]; partner or broker logs under option C	HSA

8. Cryptography and key management

Ref	Question	Response	Answer	Evidence
CRY-01	Is data encrypted in transit	Yes	HTTPS at the CDN, load balancer or reverse proxy; TLS from API to database (sslmode=require); STARTTLS to SMTP. Minimum TLS version at the edge: TLS 1.2 recommended [to confirm in the hosting runbook]	AIS, Encryption
CRY-02	Is data encrypted at rest	Partial	Storage encryption of database, file store and backups with the provider's key service in hosted options; recommended in every option. Application-level encryption only for two-step secrets	HSA, Security; AIS
CRY-03	Which algorithms are used	Yes	bcrypt for passwords; AES-256-GCM for TOTP secrets; HMAC-SHA256 for file links, reset codes and webhooks; JWT limited to HS256	AIS, OWASP table
CRY-04	How are keys and secrets managed	Yes	Secrets only in the environment or a secret store, never in the repository; separate per environment; production start refuses missing, short or placeholder secrets; sealed escrow copy of DATA_ENCRYPTION_KEY under dual control	AIS, Environment configuration; HSA
CRY-05	Who holds the encryption keys	Partial	Hosted: the provider's key service under the hosting account [to confirm whether the account is the broker's or iorta TechNXT's for each option]. Broker-hosted: the broker	HSA; AIS, Cross-border transfer
CRY-06	Can keys be rotated	Partial	JWT_SECRET rotation signs everyone out and voids file links. DATA_ENCRYPTION_KEY rotation requires users with two-step verification to enrol again; planned with the restore impact in mind	PSS, Security incidents; TR

9. Application and infrastructure security

Ref	Question	Response	Answer	Evidence
APP-01	Is the application tested against the OWASP Top 10	Yes	Controls mapped to each OWASP Top 10 (2021) risk with the code location	TR, OWASP mapping; AIS
APP-02	How is SQL injection prevented	Yes	Parameterised SQL only; 953 SQL statements reviewed on 03 October 2026; dynamic identifiers only from allow-lists in code	TR, SQL injection prevention
APP-03	Is input validated	Yes	zod schemas on bodies and queries; JSON body limit 2 MB; list pages capped at 500 rows	TR, Input validation
APP-04	Which HTTP security headers are set	Yes	helmet 8 defaults on every response (including Strict-Transport-Security, Content-Security-Policy, X-Content-Type-Options, X-Frame-Options), x-powered-by off, CORS limited to CORS_ORIGINS (* refused in production)	TR, HTTP headers
APP-05	Is there API rate limiting	Partial	600 requests per 60 seconds per user or IP; 429 with Retry-After. Counted per API instance, so the WAF should also enforce limits	TR; AIS, Known limitation
APP-06	How are file uploads protected	Partial	Type decided from the file signature; allowed types only; 10 MB per file, 10 files, 50 MB decompressed; random 128-bit keys; nosniff and sandbox CSP on download. No antivirus scan of uploads in the application [to confirm whether the hosting adds one]	TR, File uploads
APP-07	Are error messages safe	Yes	5xx answers a generic message with a request id; no stack traces to clients	AIS; TR
APP-08	Are public endpoints limited	Yes	19 public routes by design: health and version, quotation approval, payment checkout and gateway webhooks; webhooks verified by signature on the raw body, idempotent, with an amount check	TR, Public endpoints
APP-09	Is there a web application firewall	Partial	Included in the hosted design (AWS WAF, Azure Front Door WAF, ModSecurity or appliance for option C); recommended when the broker hosts	AIS, Deployment options; HSA
APP-10	Is the network segmented	Yes	Public edge, private application zone, private data zone and management zone, with only the listed traffic allowed	AIS, Network zones
APP-11	Are environments separated	Yes	DEV, UAT and PROD (small and medium broker), DEV, SIT, UAT and PROD (large broker), a temporary PRE-PROD and DR, each with its own secrets; production starts with reference data only; production personal data only in the temporary PRE-PROD restored from a backup, masked before use by people without production	AIS, Environment layout

Ref	Question	Response	Answer	Evidence
			access, deleted after use	
APP-12	Are points for the security review disclosed	Yes	Settings readable by every signed-in user (no secrets in settings); file key gives read access to signed-in users; tokens in local storage; per-instance rate limits; two-step roles empty by default	TR, Points for the security review

10. Logging and monitoring

Ref	Question	Response	Answer	Evidence
LOG-01	Is there an audit trail of business changes	Yes	audit_log with user, entity, record, action, before and after values, IP and time, written by every change; Master > Audit Trail filters by entity, record, user and date	AIS, Audit trail
LOG-02	How long is the audit trail kept	Yes	Kept by default (setting 0); if a period is set it can never be shorter than 2,557 days (seven years)	AIS, Archival
LOG-03	Are sign-in events logged	Yes	Every attempt in login_history with result, reason, IP and user agent; kept 365 days by default	TR, Audit and sign-in logging
LOG-04	Are payment notifications logged	Yes	Every gateway notification in payment_events with its signature result	AIS, Audit trail
LOG-05	Are secrets kept out of logs	Yes	JSON logs with request id; authorization headers, passwords, tokens and signatures redacted; tested (BV-SEC-030)	TSR; AIS, Monitoring
LOG-06	Can the audit trail be altered	Partial	Written by the application only; no screen edits or deletes it. Database administrators could alter it; recommended: ship logs to write-once central storage for at least one year [to confirm in the hosting runbook]	AIS, Audit trail
LOG-07	Is there security monitoring and alerting	Partial	Hosted: health checks every 5 minutes and alarms on errors, response time, capacity, jobs, failed sign-ins, token reuse, backups and certificate expiry. The deployment package itself holds no monitoring configuration	HSA; ARCH 11; PSS, Monitoring
LOG-08	Are clocks synchronised	Yes	Application and database in Asia/Manila; cloud and managed services use provider time sync; option C uses NTP [to confirm for the partner]	AIS, Common building blocks

11. Vulnerability and patch management

Ref	Question	Response	Answer	Evidence
VUL-01	Are third-party components checked for vulnerabilities	Partial	Release audit of runtime dependencies: backend 0 vulnerabilities; front end 2 moderate findings in react-router (BV-DEF-001), upgrade in the next minor release. Automated scanning in CI not yet in place	TSR, BV-DEF-001; AIS, Vulnerability management
VUL-02	What are the patching timelines	Yes	Critical security patches within 14 days and high within 30 days; operating system, PostgreSQL and nginx monthly	DPA, Annex 2; HSA; AIS; PSS, Patching
VUL-03	Has a penetration test been performed	No	No external penetration test yet. An independent test is recommended before go-live and committed yearly in the DPA; the summary is shared with the broker	TSR, Security testing; DPA, Audits
VUL-04	What internal security testing was done	Yes	Authentication on every endpoint, tokens, password policy, lockout, two-step verification, role probes, injection probes, document links, headers, secrets in logs, dependency audit	TSR, Security testing performed
VUL-05	Are base images and the runtime current	Yes	node:22-alpine, nginx:1.27-alpine, postgres:16-alpine; rebuilt with each release and at least quarterly	AIS; PSS, Patching
VUL-06	Are unsupported components in use	Partial	Create React App (react-scripts 5.0.1) is no longer maintained; most front-end advisories are build-time only; move to Vite planned	AIS, Vulnerability management

12. Secure development and change management

Ref	Question	Response	Answer	Evidence
SDL-01	Is there a defined SDLC with code review	Partial	Pull requests run CI (lint, backend tests against PostgreSQL 16, front-end tests). Branch protection with required reviews is recommended and not yet enforced	AIS, Secure development lifecycle
SDL-02	What automated tests exist	Yes	634 backend business-rule tests (03 October 2026), 43 front-end tests, a 371-step end-to-end UAT cycle with one user per role	TSR, Approach
SDL-03	Do deployments run the tests	Partial	Gap: the deploy workflow does not run lint and tests on push; tests run on pull requests only. Remedy: restore test jobs as a dependency of deployment	AIS, CI/CD
SDL-04	Are coding standards documented	Yes	Naming, route registry, zod validation, error envelope, parameterised SQL, audit, settings, logging, lint rules (no-console, eqeqeq)	TR, Coding standards
SDL-05	Are secrets kept out of source code	Yes	No secret in the repository; .env.example files carry placeholders that production refuses	TR, Encryption and secrets
SDL-06	How are database changes controlled	Yes	Numbered migrations that only add, applied in transactions under an advisory lock and recorded; snapshot before each release with migrations	AIS, Database migrations
SDL-07	How are production changes approved	Yes	CAB approval with test evidence; UAT scripts by the broker; maintenance window announced 5 business days ahead; rollback plan	PSS, Change and release management
SDL-08	Is there an inventory of APIs	Yes	npm run export:api writes OpenAPI, Postman and Excel lists of every route with its permission	AIS; TR, API catalogue
SDL-09	Are developers trained in secure coding	Partial	[to confirm: training programme]	

13. Backup, continuity and disaster recovery

Ref	Question	Response	Answer	Evidence
BCP-01	How is data backed up	Yes	Hosted: automated database backups with PITR (35 days), daily snapshots, monthly copies to a second region or site, monthly logical dump to write-once storage, daily file store backup, snapshot before releases and year-end	HSA, Backups; BCDR
BCP-02	Are backups encrypted and kept off-site	Yes	Encrypted snapshots; cross-region or second-site copies; write-once storage for monthly dumps	AIS, Backup; BCDR
BCP-03	What are the RTO and RPO	Partial	Proposed: database restore RPO 15 minutes, RTO 4 hours; in-region failure RPO 0, RTO 15 minutes; region or site loss RPO and RTO 24 hours (8 hours with warm standby). Binding once accepted in the Order Form and provisioned	BCDR; HSA, Recovery objectives
BCP-04	Are restores tested	Yes	Daily backup check; PITR restore quarterly and before go-live; dump restore twice a year; secret escrow yearly; results in the monthly service report	PSS, Backup verification; HSA
BCP-05	Is there a DR plan and is it exercised	Yes	Business Continuity and Disaster Recovery Plan; tabletop yearly, full recovery every two years	BCDR; HSA
BCP-06	Is a DR environment included	Partial	Included for the Enterprise size; optional for other sizes (Order Form). Without it, recovery after a region loss is from cross-region backups	HSA, Recovery objectives; BCDR
BCP-07	Does the provider have its own business continuity plan for the support team	Partial	Support continuity measures are in BCDR (key person, knowledge base, escrow). iorta TechNXT corporate BCP: [to confirm]	BCDR, Scenarios

14. Incident management

Ref	Question	Response	Answer	Evidence
INC-01	Is there a documented incident response process	Yes	Suspected security incidents are P1: contain, preserve evidence, assess, recover, report and learn	PSS, Security incidents
INC-02	How fast is the broker informed	Yes	P1 first response in 30 minutes; personal data breach notice within [24] hours of discovery	SLA; DPA
INC-03	What evidence is kept	Yes	Logs, login_history, audit_log, monitoring data and a database snapshot	DPA, Containment and evidence
INC-04	Is there root-cause analysis	Yes	Written RCA for every P1 and every problem record, draft to the broker within 5 business days of restore; known-error records in the knowledge base	PSS, Root-cause analysis
INC-05	Who notifies the NPC	Broker	The broker's DPO decides and notifies within 72 hours where required; iorta TechNXT supplies the facts	DPA; PSS

15. Subcontractors, hosting and data residency

Ref	Question	Response	Answer	Evidence
SUB-01	Which hosting options are offered	Yes	A: AWS ap-southeast-1 (Singapore); B: Azure Southeast Asia (Singapore); C: Philippine hosting partner; or hosting by the broker	AIS, Deployment options; HSA
SUB-02	Can the data stay in the Philippines	Yes	Option C or broker hosting keeps data, backups and the off-site copy in the Philippines	HSA, Data location
SUB-03	Who is the Philippine hosting partner	Partial	[to confirm: partner name, data centre city, certifications]	HSA; DPA, Annex 3
SUB-04	Are subcontractors bound to equivalent obligations	Yes	By written contract with obligations no less protective than the DPA; iorta TechNXT remains responsible	DPA, Sub-processors
SUB-05	Is support provided from outside the Philippines	Partial	[to confirm: location of L2 and L3 teams and whether they access production data from abroad]. If yes, this is a further transfer the broker documents	PSS; DPA
SUB-06	Can the broker host the system itself	Yes	Yes, with the deployment guide; no hosting fee; set-up support at day rates	AIS; Rate Card

16. Audit and assurance

Ref	Question	Response	Answer	Evidence
AUD-01	Does the broker have a right to audit	Yes	Once a year on 30 days' notice, by the broker or an approved independent auditor under confidentiality; extra audits after a breach or when the NPC requires	DPA, Audits
AUD-02	What evidence is provided without an on-site audit	Yes	Policies, the penetration test summary, sub-processor certifications, monthly service reports, restore test records	DPA, Audits; PSS
AUD-03	Can regulators audit the provider	Partial	NPC: under the DPA audit clause. IC: disclosure to the IC is allowed; a direct examination right for the IC: [to confirm in the MSA]	MSA; DPA
AUD-04	Are the product's controls documented for the broker's auditors	Yes	AIS compliance checklist; PRCM; TSR with 497 test cases and traceability to automated tests	AIS; PRCM; TSR

17. Open items before release to a broker

#	Item	Owner
1	Company registration details, financial statements, insurance cover (GOV-01, GOV-13, GOV-14)	iorta TechNXT management
2	Information security policy, security officer, DPO and NPC registration (GOV-03 to GOV-05)	iorta TechNXT management
3	ISO/IEC 27001 and SOC 2 plan with dates (GOV-06, GOV-07)	iorta TechNXT management
4	Staff screening and training (GOV-10, GOV-12, SDL-09)	iorta TechNXT HR
5	Production access list and approval, cloud audit logging, log shipping (ACC-16, ACC-17, LOG-06)	iorta TechNXT DevOps
6	Key ownership per hosting option, TLS minimum, antivirus on uploads (CRY-01, CRY-05, APP-06)	iorta TechNXT DevOps
7	Philippine hosting partner and support team location (SUB-03, SUB-05)	iorta TechNXT management
8	IC circular numbers and IC examination right (REG-01, REG-03, AUD-03)	Broker compliance officer with iorta TechNXT legal

18. Document Sign-Off

Serial Number	Description	Owner	Status
1	Answers marked [to confirm] need a signed-off answer from iorta TechNXT management before the questionnaire is released to a broker	iorta TechNXT	Open

Sign Off Date	Signature	Approved By	Department & Project Role



Insurance technology for the Philippines



10+

COUNTRIES

Global Presence



8

GLOBAL OFFICES

Strategically Located



11+

MARKETS SERVED

Across Continents



100%

COMMITMENT

To Excellence



MALAYSIA



INDIA



PHILIPPINES



THAILAND



VIETNAM



USA



ETHIOPIA



CAMBODIA



HONGKONG



SINGAPORE



Scan More Details